

# How Blackbaud SKY Grants Access

Prepared for Melissa Neatherlin and Omar Peraza · Trinity Christian Academy · 3 September 2026

**The question:** why does AthleticOS want a service account, when no prior app integration needed one?

**The short answer:** a service account is how you give an integration *less* access than it would otherwise get. It is the smaller of the available options, not the larger one. This page explains why, so the choice is yours to make on the facts.

## SKY USES TWO CREDENTIALS, AND ONLY ONE OF THEM CARRIES PERMISSIONS

| CREDENTIAL                                         | WHAT IT DOES                                                                                                                    | WHAT IT DOES NOT DO                                                                                                                                                             |
|----------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Subscription key</b><br>Bb-API-Subscription-Key | Identifies the application to Blackbaud's gateway. Governs rate limits and daily quota.                                         | Carries no permission to read any data. Tested directly: a valid key with no token returns <i>"The required Authorization header was missing."</i> The key alone reads nothing. |
| <b>OAuth access token</b><br>Authorization: Bearer | Carries every data permission the integration has. Obtained only when a real person signs in to Blackbaud and approves the app. | Cannot be issued to an application on its own. There is no machine-to-machine path; SKY offers only the interactive sign-in flow.                                               |

## THERE ARE NO PER-APP SCOPES IN SKY

Most modern APIs let you issue a key and attach scopes to it, for example *read schedules only*. SKY does not work that way. Blackbaud's own OAuth discovery document at `oauth2.sky.blackbaud.com` publishes **no scopes\_supported list at all**, and its `response_types_supported` is `["code"]` alone, meaning an interactive human sign-in is the only route to a token.

Because no scopes exist, the app cannot request narrower access and TCA cannot grant it per endpoint. **A token's power is exactly whatever the person who approved it can do in Blackbaud.**

**Put another way:** you are not issuing the app a badge that reads *"athletics schedules, read only."* No such badge exists. You are cloning a specific person's badge and handing the copy to the application.

Clone a limited account's badge, and the app opens only what that account opens. Clone an administrator's badge, and the app holds administrator capability for as long as the connection lives, whether or not it ever uses it.

## THREE WAYS TCA CAN AUTHORIZE ATHLETICOS

All three work. AthleticOS is content with any of them, and the differences are real, so the decision belongs to TCA.

| OPTION                                                             | APP RECEIVES                                                      | TRADE-OFF                                                                                                                                                                                                                                                          |
|--------------------------------------------------------------------|-------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>1. Read-only service account</b><br><b>LEAST ACCESS</b>         | Read on athletics and calendar. Nothing else.                     | Writing is structurally impossible rather than merely promised. Activity stays separable from staff activity in the audit log, and the account can be disabled without affecting any person. Costs TCA the setup work, which is the real objection and a fair one. |
| <b>2. An existing limited account</b><br><b>LEAST ACCESS</b>       | Whatever that account already holds.                              | Same benefit as option 1 with no new account to create, if a suitable non-admin account already exists.                                                                                                                                                            |
| <b>3. An administrator approves it</b><br><b>FULL ADMIN ACCESS</b> | Everything that administrator can do, including write and delete. | Simplest for TCA and identical to how prior integrations were approved. Read-only then rests on AthleticOS's commitment and the audit log rather than on the account itself.                                                                                       |

Note on the roles previously listed: `SKY API Basic` and `SKY API Data Sync` are what Blackbaud documents as required for an account to authorize and maintain a connected app. `Sky Reporting` was included in error, taken from a third-party setup guide and not confirmed as necessary for the endpoints below. Recommend starting with the minimum and adding only if a call actually fails.

## WHAT ATHLETICOS CALLS, AND HOW TO STOP IT

Four endpoints, all read, pilot team only: `calendars/...` (master calendar, for conflict detection), `athletics/teams`, `athletics/teams/{id}/schedule`, and `athletics/teams/{id}/roster` (early-release workflow), each under `/school/v1/`.

No writes of any kind during the pilot. Every call is logged with timestamp, endpoint and response code, available to TCA on request. Nothing touching financial data, advancement, the LMS, grades or health records. **To revoke:** deactivate AthleticOS in the Applications area. Access stops immediately, with no code change and no cooperation needed from AthleticOS.